Risk Register: RAG-Diary

> ทะเบียนความเสี่ยงของโครงการ ประเมินด้วยโอกาสและผลกระทบ พร้อมแนวทางรับมือ และเจ้าของความเสี่ยง เพื่อให้ทีมเฝ้าระวังและจัดการได้ก่อนเกิดปัญหา

1. Document Control

หัวข้อ	รายละเอียด
ชื่อเอกสาร	Risk Register
เวอร์ชัน	1.1
วันที่จัดทำ	15 ตุลาคม 2569
ผู้จัดทำ	Business Analyst / System Analyst (เจ้าของผลงาน)
สถานะ	ผ่านการตรวจทานรอบ 1 (25 ตุลาคม 2569) และทบทวนเพิ่ม R-12 ถึง R-13 วันที่ 14 พฤศจิกายน 2569
เอกสารที่เกี่ยวข้อง	ADR, DFD-PRIVACY, SRS, NFR-SPEC

2. Purpose และ Scope

เอกสารนี้ตอบคำถามว่า "อะไรที่อาจทำให้โครงการสะดุด และเราจะรับมืออย่างไร" โดยรวบรวมความเสี่ยงทั้งด้านเทคนิค ความปลอดภัยและความเป็นส่วนตัว ค่าใช้จ่าย การส่งมอบ และผลิตภัณฑ์

ขอบเขต: ความเสี่ยงที่ยังไม่เกิด พร้อมการประเมินและการรับมือ นอกขอบเขต: ปัญหาที่เกิดขึ้นแล้ว (อยู่ใน CHANGE-REQUEST-LOG)

3. วิธีประเมิน

แต่ละความเสี่ยงให้ค่าคะแนนโอกาส (1-5) คูณผลกระทบ (1-5) เป็นคะแนนความเสี่ยง แล้วแบ่งระดับดังนี้

ช่วงคะแนน	ระดับ	ความหมาย
1-4	Low	เฝ้าระวังตามรอบ
5-9	Medium	มีแผนรับมือและติดตาม
10-15	High	ต้องมีแผนรับมือชัดเจนและผู้รับผิดชอบ
16-25	Critical	ต้องจัดการทันทีหรือลดความเสี่ยงก่อน

4. ทะเบียนความเสี่ยง

รหัส	ประเภท	ความเสี่ยง	โอกาส	ผลกระทบ	คะแนน	ระดับ	แนวทางรับมือ	เจ้าของ	สถานะ
R-01	ความปลอดภัย	token เก็บใน localStorage เสี่ยงถูกขโมยผ่านสคริปต์	4	5	20	Critical	ย้ายไป cookie แบบ httpOnly และลดอายุ token	Dev	ลดแล้ว (ย้ายเป็น httpOnly cookie ผ่าน same-origin proxy, ADR-10)
R-04	ความเป็นส่วนตัว	ส่งข้อมูลส่วนตัวไปประมวลผลภายนอกโดยไม่ยินยอมชัดเจน	4	5	20	Critical	แจ้งและขอความยินยอม (consent gate ใช้งานแล้ว) ลดข้อมูลเท่าที่จำเป็น จัดทำข้อตกลงผู้ประมวลผล	DPO	กำลังลด
R-02	ความปลอดภัย ค่าใช้จ่าย	ไม่มีข้อจำกัดอัตราการเรียก เสี่ยงถูกใช้เกินและค่าใช้จ่ายพุ่ง	4	4	16	Critical	จำกัดอัตราต่อผู้ใช้ แจ้งเตือนเพดานค่าใช้จ่าย	Dev, Ops	ปิดแล้ว (เปิดใช้ 12 พ.ย. 2569; แยกตัวนับตามเส้นทาง 14 พ.ย. 2569 และตรวจ 429 แล้ว)
R-10	การส่งมอบ	ผู้ดูแลหลักคนเดียว (bus factor ต่ำ)	4	4	16	Critical	จัดทำเอกสารชุดนี้และส่งมอบความรู้	PO	กำลังลด
R-03	ความปลอดภัย	ปลายทางสรุปรับข้อมูลแบบไม่ตรวจชนิด	3	4	12	High	กำหนดสคีมาให้ชัดและตรวจข้อมูลก่อนใช้	Dev	ปิด (แก้แล้ว)
R-05	ผลิตภัณฑ์	ผูกกับผู้ให้บริการ AI รายเดียว เสี่ยงบริการล่มหรือราคาเปลี่ยน	3	4	12	High	ทำชั้นเชื่อมที่สลับผู้ให้บริการได้และมีทางสำรอง	Dev	เปิด
R-07	ผลิตภัณฑ์	คุณภาพการค้นคืนต่ำ ทำให้ผู้ใช้ไม่เชื่อถือคำตอบ	3	4	12	High	ปรับค่า threshold และเก็บผลตอบรับเพื่อประเมิน	PO, Dev	กำลังลด (ปรับ threshold เป็น 0.6 แล้ว; ยังไม่เก็บผลตอบรับ)
R-06	ค่าใช้จ่าย	ค่าใช้จ่ายสร้างเวกเตอร์และสร้างภาพสูงเมื่อผู้ใช้โต	4	3	12	High	ตั้งโควตา ใช้แคช และติดตามการใช้	Ops	เปิด
R-09	การส่งมอบ	ไม่มีชุดทดสอบอัตโนมัติและ CI เสี่ยงข้อผิดพลาดย้อนกลับ	4	3	12	High	เพิ่มชุดทดสอบและ CI ขั้นต่ำ	QA, Dev	ลดแล้ว (22 unit tests + GitHub Actions)
R-08	ความปลอดภัย	ปลายทางคืนทุกคอลัมน์รวม embedding และ user_id	3	3	9	Medium	เลือกคอลัมน์ที่ต้องการส่งกลับ	Dev	ปิด (แก้แล้ว)
R-11	เทคนิค	ประสิทธิภาพการค้นเวกเตอร์ลดลงเมื่อข้อมูลโตมาก	2	4	8	Medium	ทดสอบโหลดที่ 5,000 บันทึกแล้ว (p95 0.41 วินาทีที่ชั้น DB) และปรับดัชนี HNSW ต่อเมื่อข้อมูลโตกว่านี้	Dev	ลดแล้ว
R-12	เทคนิค	ระบบไม่เสถียรเมื่อมีผู้ใช้พร้อมกันสูง (พบ	3	4	12	High	ตรวจขีดจำกัด connection pool ทดลอง retry และวัดซ้ำ	Dev	เปิด

รหัส	ประเภท	ความเสี่ยง	โอกาส	ผลกระทบ	คะแนน	ระดับ	แนวทางรับมือ	เจ้าของ	สถานะ
		HTTP 500 ที่ 20 ผู้ใช้)					ที่ 10 20 30 ผู้ใช้ ก่อนรับงาน		
R-13	ความปลอดภัย	ข้อมูลทดสอบที่มีรหัสผ่านถูก commit เป็นหลักฐาน	2	3	6	Medium	กรองรหัสก่อนเขียนไฟล์ ลบบัญชีทดสอบ และหลีกเลี่ยงการเก็บรหัสจริงในไฟล์ที่ commit	Dev	ปิดแล้ว (14 พ.ย. 2569)

5. แผนผังความร้อน (โอกาส x ผลกระทบ)

ผลกระทบ \ โอกาส	1	2	3	4	5
5				R-01, R-04	
4			R-03, R-05, R-07, R-12	R-02, R-10	
3		R-13	R-08	R-06, R-09	
2		R-11			
1					

6. ความเสี่ยงที่ต้องจับตาเป็นพิเศษ

รหัส	เหตุที่ต้องจับตา	สัญญาณเตือนล่วงหน้า
R-01	ผลกระทบสูงและแก้ไขภายหลังยากขึ้นเรื่อย ๆ	พบช่องโหว่สคริปต์หรือมีรายงานความปลอดภัย
R-04	กระทบข้อกำหนดด้านข้อมูลส่วนบุคคลโดยตรง	มีการนำข้อมูลผู้ใช้จริงไปทดสอบโดยไม่ยินยอม
R-02	เกิดเร็วและกระทบทั้งความปลอดภัยและค่าใช้จ่าย	ค่าใช้จ่าย AI รายวันสูงผิดปกติ
R-10	กระทบความต่อเนื่องหากผู้ดูแลไม่อยู่	งานค้างไม่มีผู้รับช่วง

7. รอบการทบทวน

ทบทวนทะเบียนความเสี่ยงทุกสองสัปดาห์ หรือเมื่อมีความเสี่ยงใหม่ที่คะแนนระดับ High ขึ้นไปเกิดขึ้น

8. References

เอกสาร	ความสัมพันธ์
ADR	ที่มาของความเสี่ยง R-01 และ R-05
DFD-PRIVACY	ที่มาของความเสี่ยง R-04
NFR-SPEC	คุณภาพที่ความเสี่ยงเหล่านี้คุกคาม
CHANGE-REQUEST-LOG	บันทึกเมื่อความเสี่ยงกลายเป็นปัญหาจริง